

- **Lab Title:** Web Application Vulnerability Discovery and Exploitation Using DVWA and Metasploitable
- **Assignment Title:** Web Application Vulnerability Discovery and Exploitation Using DVWA and Metasploitable
- **Student Name:** Bashir Adam
- **Student ID:** 2025/FWSD/11509
- **Course Name:** BVWS102 – Web Application Security Essentials
- **Instructor Name:** Aminu Idris
- **Date of Submission:** 13 JAN, 2026
- **Version:** Version 1.5.0

LAB OVERVIEW/OBJECTIVE

The objective of this lab is to demonstrate hands-on understanding of multiple OWASP Top 10 web vulnerabilities through guided discovery and controlled exploitation, strictly following the step-by-step procedures demonstrated in the instructor's recorded video sessions.

Students will:

- Discover and exploit Command Execution in DVWA.
- Obtain reverse shell access using Netcat.
- Discover and exploit Local File Inclusion (LFI) using Burp Suite to achieve a reverse shell.
- Discover Cross-Site Scripting (XSS) vulnerabilities (discovery only, no exploitation).
- Perform a full automated vulnerability scan of the Metasploitable VM using OWASP ZAP.

Lab Environment

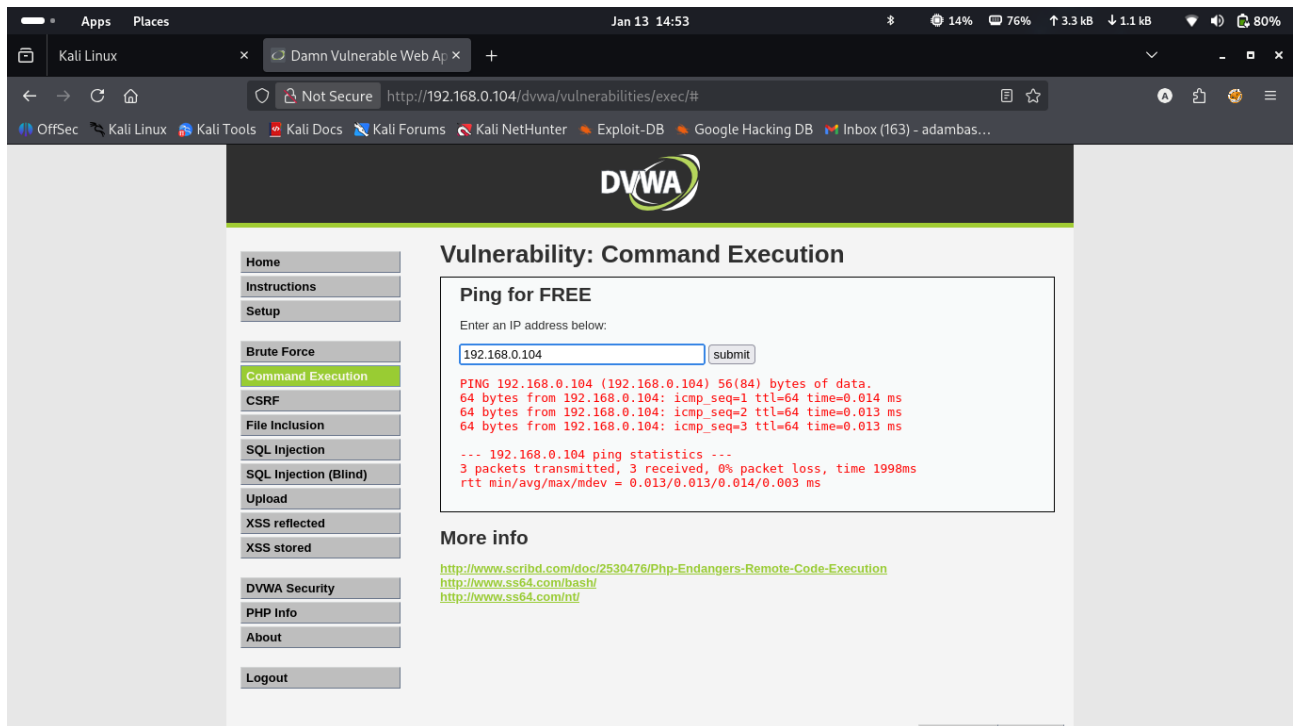
- Vulnerable Application: Damn Vulnerable Web Application (DVWA)
- Target System: Metasploitable VM
- Platform: VirtualBox or VMware
- Security Level: DVWA (as demonstrated in video guide)
- Tools:
 - Netcat
 - Burp Suite
 - OWASP ZA

PART A: COMMAND EXECUTION (DVWA)

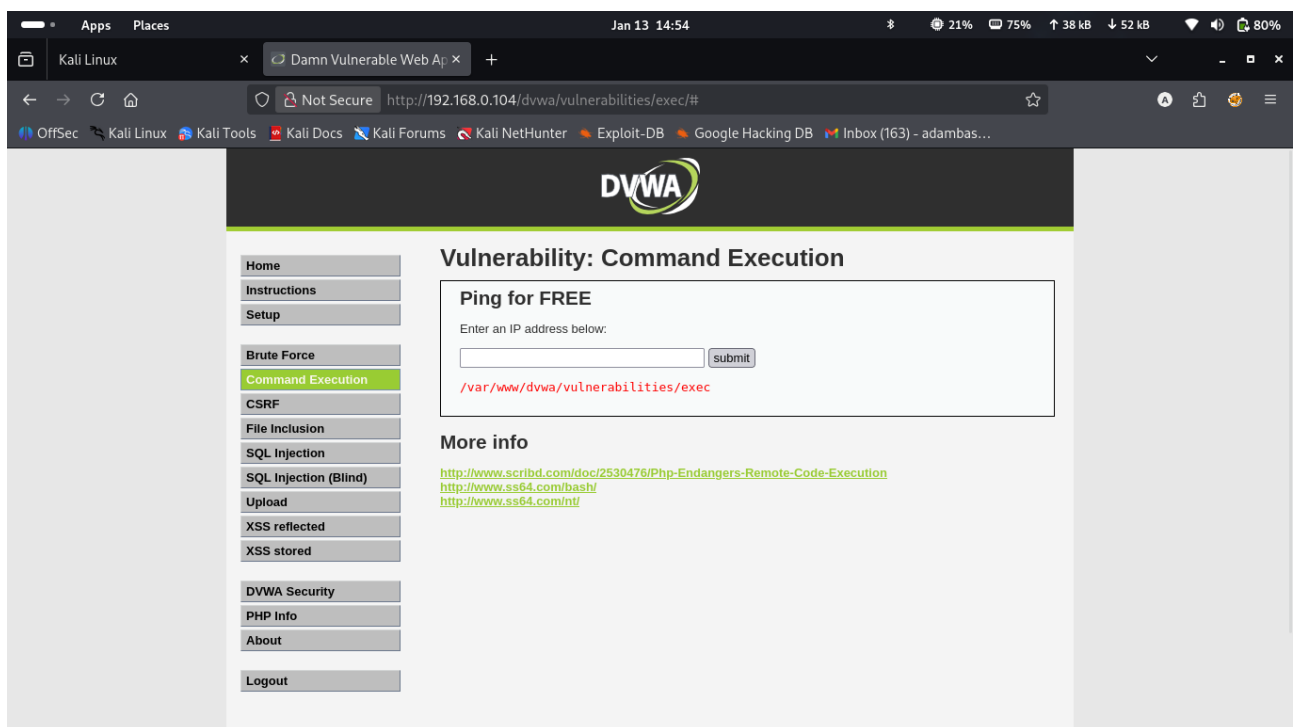
Objective

To discover and exploit a Command Execution vulnerability in DVWA and obtain a reverse shell.

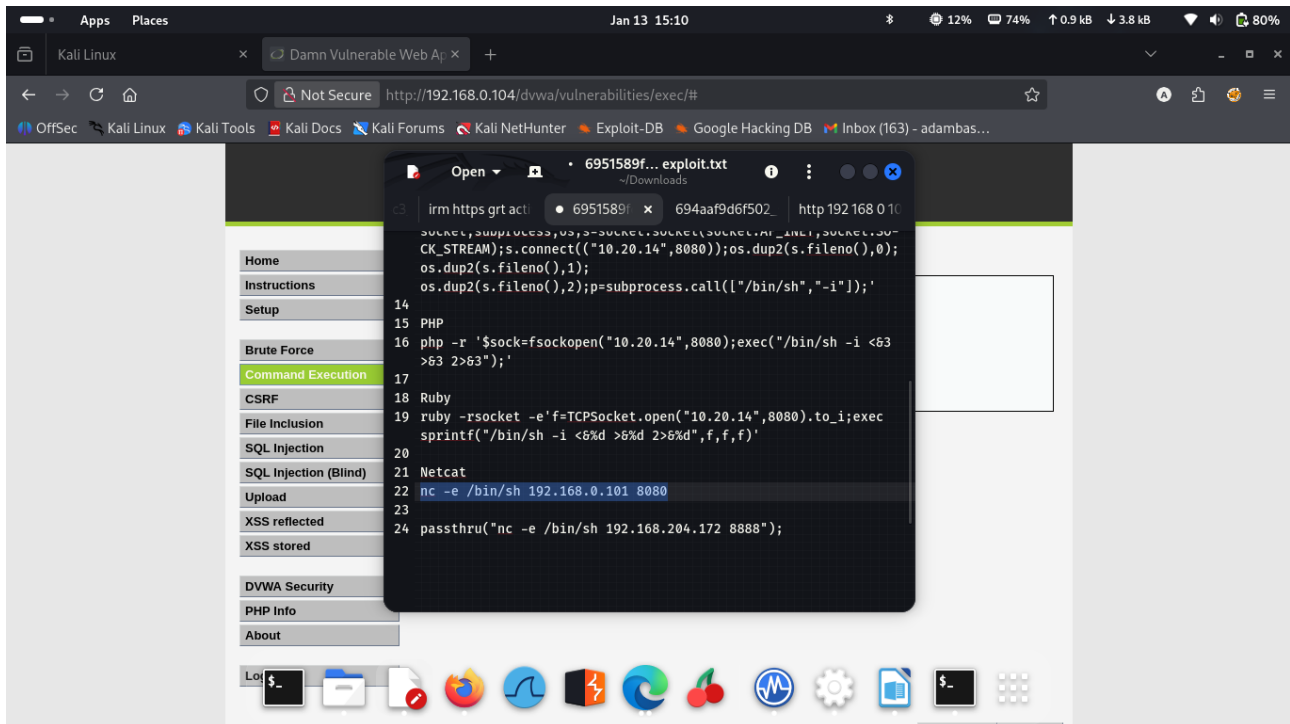
I first of all ping my IP address



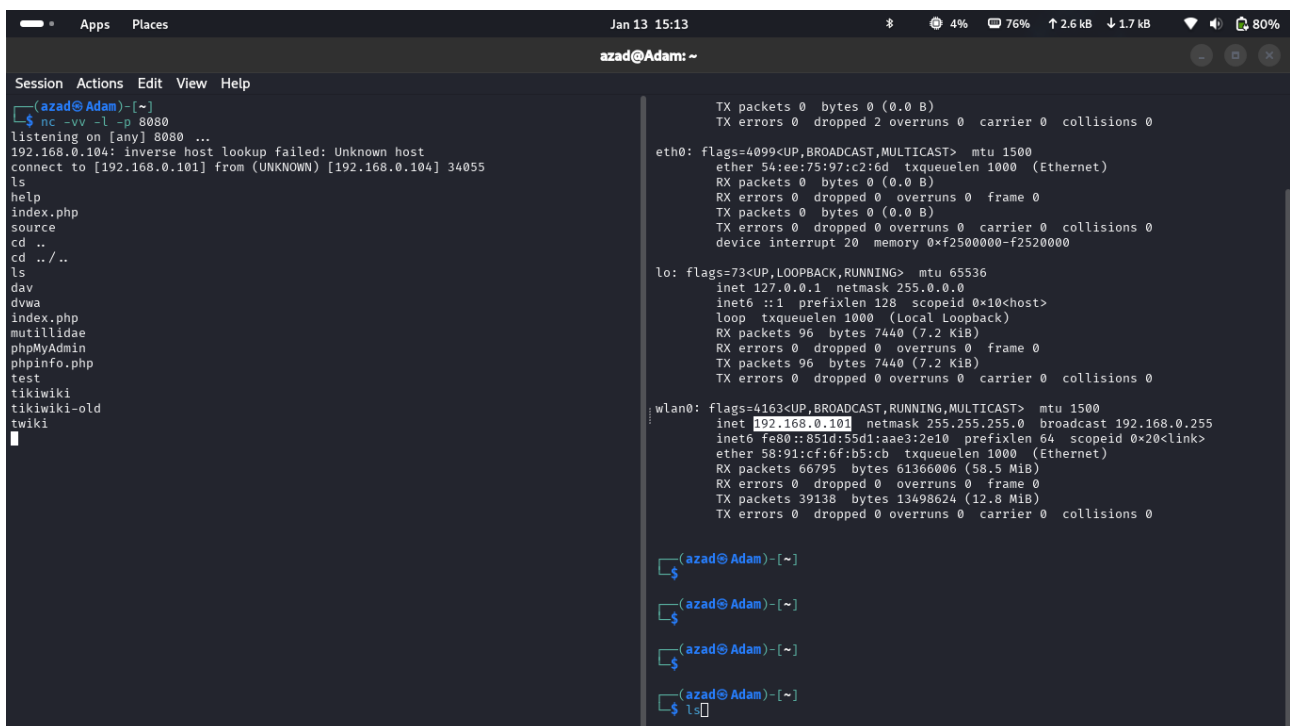
Then I try to discover and exploit Command Execution in DVWA. And that



I prepare my injection payloads



I test my port to verify my listener



Successfully establish a Netcat reverse shell connection

```

  A  Apps  Places

Jan 23 15:15
azad@Adam: ~

Session Actions Edit View Help

<label for="pass">Password</label> <input type="password"
d" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />

name="Login"></p>

</fieldset>

</form>

<br />

{$messagesHtml}

<br />
<br />
<br />
<br />
<br />
<br />
<br />

<img src="" .DVWA_WEB_PAGE_TO_ROOT."dwva/images/RandomStorm.png" />

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

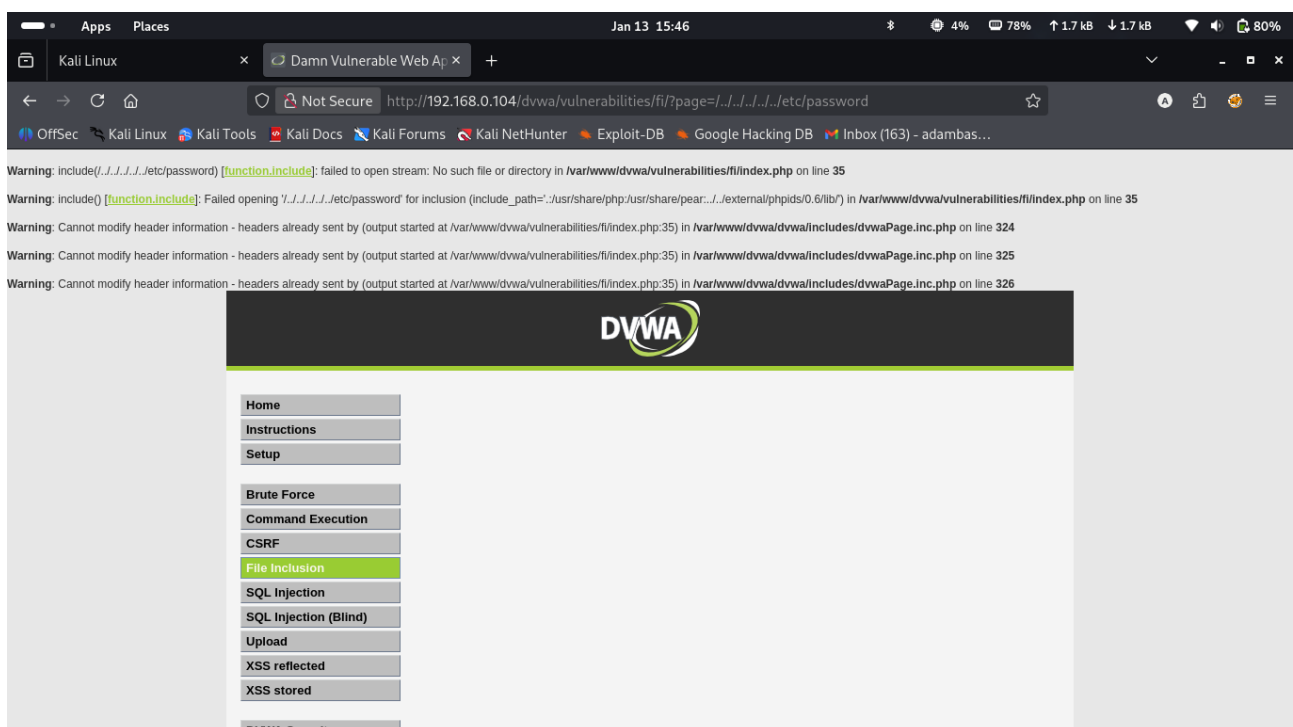
</html>
";
?>

```

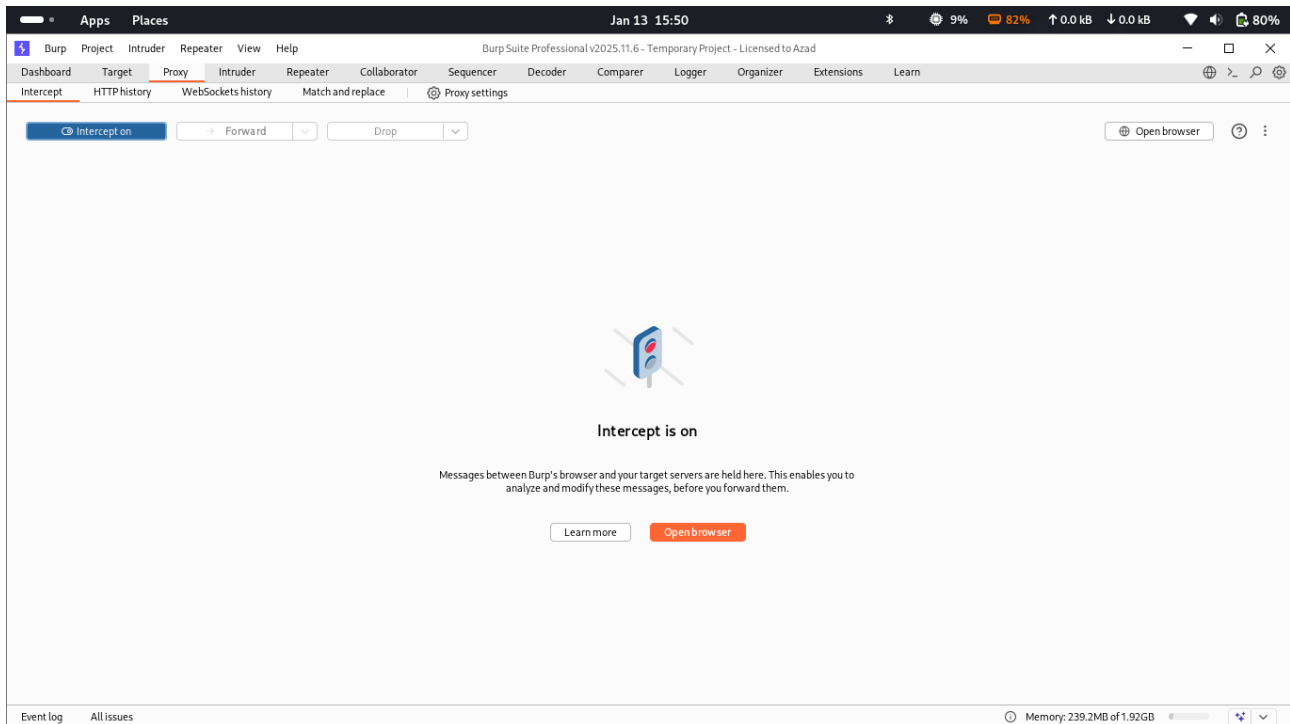
PART B: LOCAL FILE INCLUSION (LFI) WITH BURP SUITE (DVWA)

To discover and exploit a Local File Inclusion (LFI) vulnerability using Burp Suite, leading to a reverse shell.

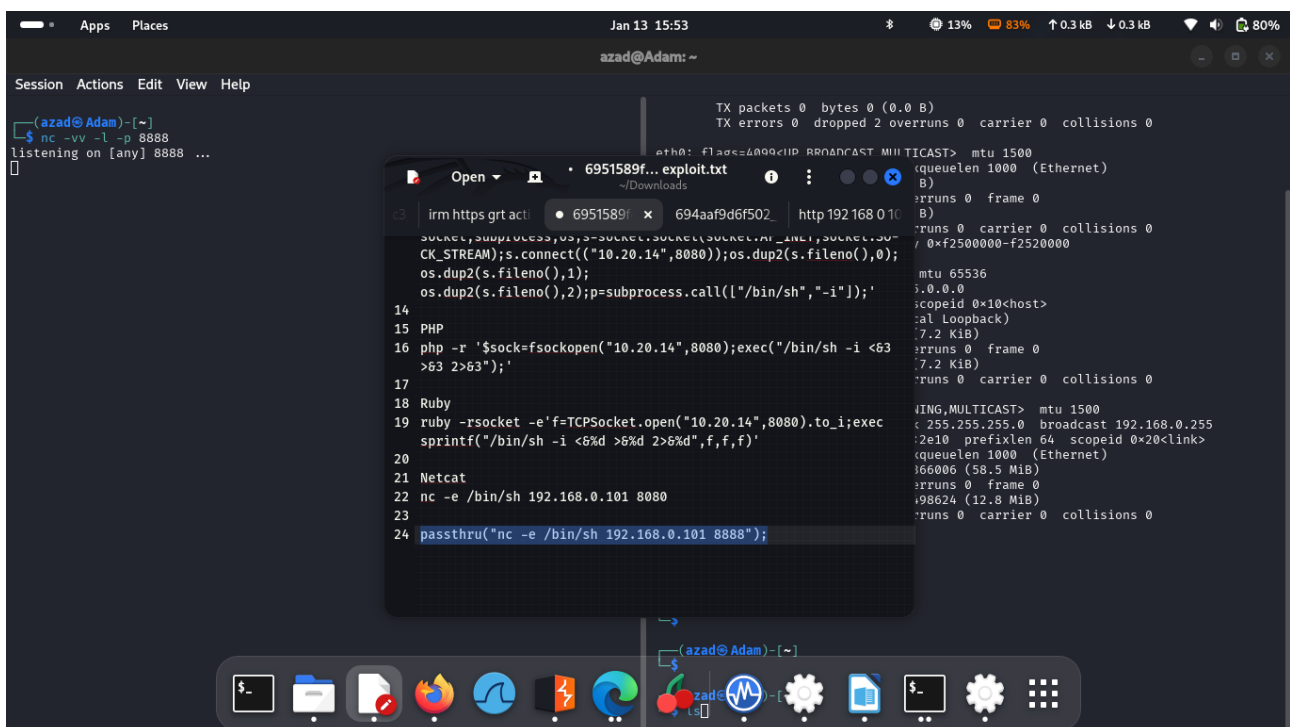
I identify the File Inclusion vulnerability module in DVWA.



Then I open my burpsute and open my interceptor



I modify my payloads



The I intercept the request send from my browse

The screenshot shows the Burp Suite Professional interface. The top menu bar includes 'Apps', 'Places', and a date/time display of 'Jan 13 16:06'. The main toolbar has buttons for 'Intercept on', 'Forward', and 'Drop all'. Below this, a table lists intercepted requests. The first request is an HTTP GET to 'http://192.168.0.104/dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ'. The 'Request' tab is selected, showing the raw HTTP request details. The 'Inspector' tab on the right shows the request headers, including 'Host: 192.168.0.104', 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0', 'Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8', 'Accept-Language: en-US,en;q=0.5', 'Accept-Encoding: gzip, deflate, br', 'Connection: keep-alive', 'Cookie: security=low; PHPSESSID=1271412ea4d8ed9f227909e116154c0e', 'Upgrade-Insecure-Requests: 1', and 'Priority: u=0, i'.

Time	Type	Direction	Method	URL	Status code	Length
16:06:2613...	HTTP	→ Request	GET	http://192.168.0.104/dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ		

Request

Pretty Raw Hex

```
1 GET /dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ HTTP/1.1
2 Host: 192.168.0.104
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: security=low; PHPSESSID=1271412ea4d8ed9f227909e116154c0e
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Inspector

Request attributes: 2

Request query parameters: 1

Request body parameters: 0

Request cookies: 2

Request headers: 9

Name	Value
Host	192.168.0.104
User-Agent	Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language	en-US,en;q=0.5
Accept-Encoding	gzip, deflate, br
Connection	keep-alive
Cookie	security=low; PHPSESSID=1271412ea4d8ed9f227909e116154c0e
Upgrade-Insecure-Requests	1
Priority	u=0, i

Event log (1) All issues (2)

Memory: 193.5MB of 1.92GB

And I don't know what happened with it still give me error

The screenshot shows a web browser window with the address bar displaying 'http://192.168.0.104/dvwa/vulnerabilities/fi/?page=../../../../proc/self/environ'. The page content shows several warning messages:

- Warning: include(/../../../../proc/self/environ) [function.include]: failed to open stream: No such file or directory in /var/www/dvwa/vulnerabilities/fi/index.php on line 35
- Warning: include() [function.include]: Failed opening '../../../../proc/self/environ' for inclusion (include_path='.:/usr/share/php:/usr/share/pear:/external/phpids/0.6/lib') in /var/www/dvwa/vulnerabilities/fi/index.php on line 35
- Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 324
- Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 325
- Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/fi/index.php:35) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 326

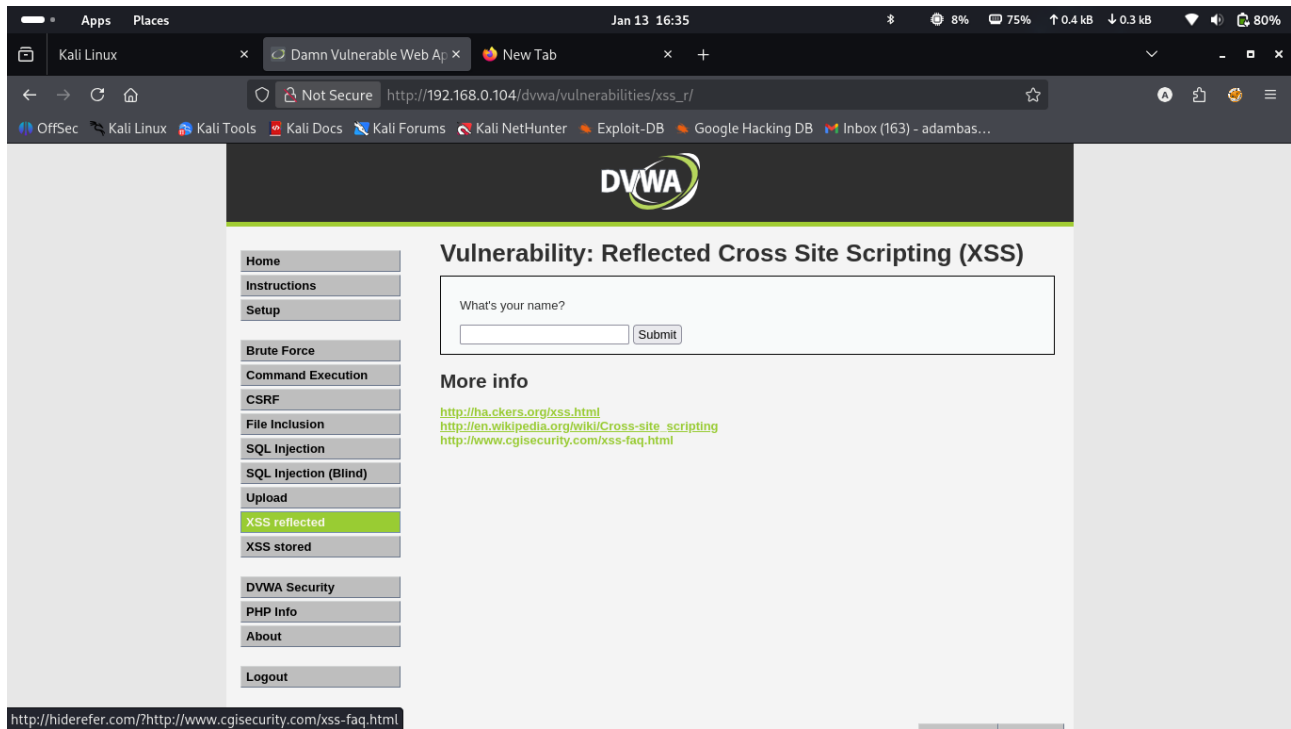
The DVWA application interface is visible, showing a sidebar with navigation links: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion (highlighted), SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, and DVWA Security.

PART C: CROSS-SITE SCRIPTING (XSS) – DISCOVERY ONLY

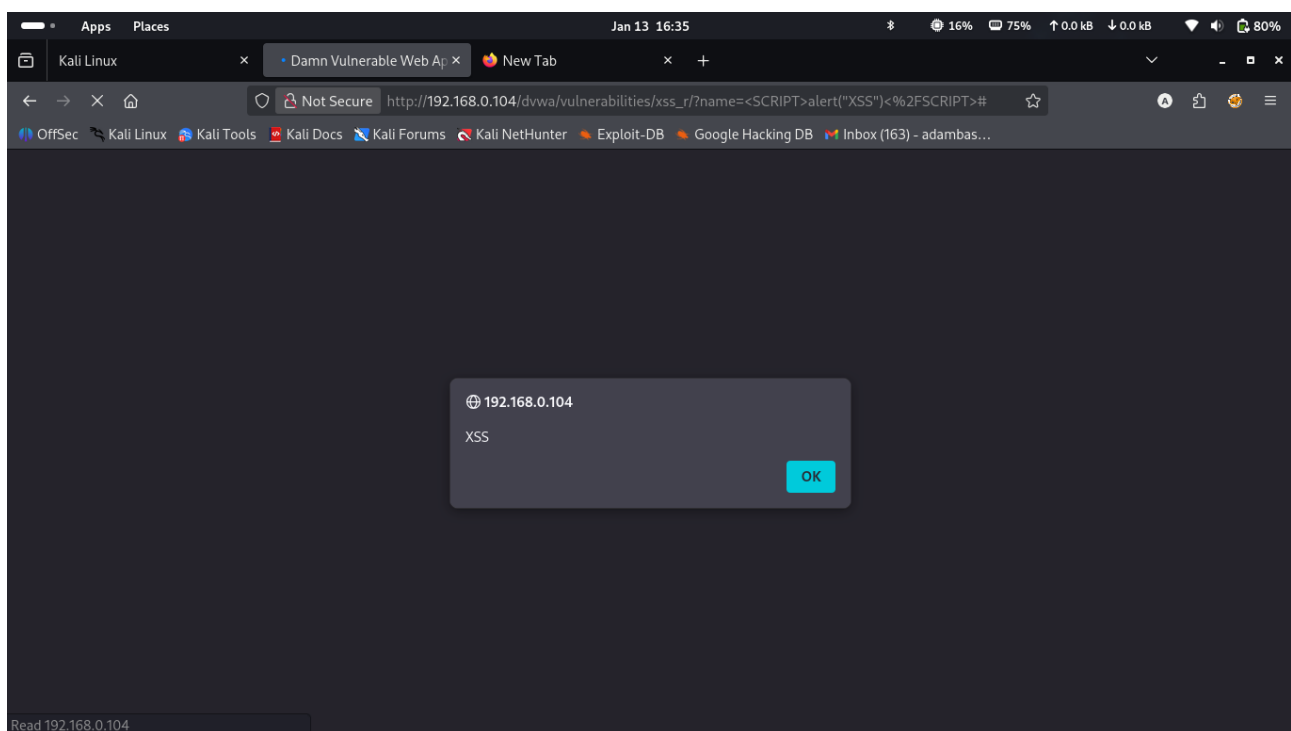
Objective

To identify the presence of XSS vulnerabilities without exploitation.

After navigating to the XSS vulnerability modules in DVWA



Then I try to inject a particular alert payloads and this work successfully



PART D: AUTOMATED VULNERABILITY SCANNING WITH OWASP ZAP

Objective

To perform a comprehensive vulnerability scan of the Metasploitable VM using OWASP ZAP.

This is the last part of my assignment where I have successfully perform a full automated scan of my target system where I identify the risk level as medium and the url <https://192.168.174.128>

